Bilag 9.1 Spørgeskema til brug for Kundens risikovurdering af it- og informationssikkerhed

Herunder GDPR artikel 32-risikovurdering og fastlæggelse af sikkerhedskrav

Dynamisk indkøbssystem 02.19 Fagsystemer (2024)

Kontrakt om levering af ESDH løsning til Danmarks Nationalbank

SKI0219.2503.0030

Udfyldes af Leverandøren

Staten og Kommunernes Indkøbsservice A/S
Montagehallen | Pakkerivej 6, 2500 Valby
Telefon +45 33 42 70 00 | CVR 17472437

Indhold

1 Vejledning 2
2 Netværk og tekniske behandlingsmidler 3
3 Processer og procedurer relateret til behandlingen 5
4 Personer og parter involveret i behandlingen 6
5 Sektorspecifikke trusler og behandlingens omfang 8

1 Vejledning

[***Vejledning til Leverandøren***

Leverandøren bedes udfylde nedenstående spørgeskema til brug for Kundens risikovurdering af risici for brud på IT- og informationssikkerheden samt risikovurdering af risici for brud på persondatasikkerheden efter databeskyttelsesforordningens artikel 32.

Kundens risikovurderinger består af en sammenholdelse af konsekvensen ved og sandsynligheden for et brud på IT- og informationssikkerheden samt persondatasikkerheden. Spørgeskemaets indhold skal bidrage til Kundens vurdering af sandsynligheden for et brud på IT- og informationssikkerheden samt persondatasikkerheden. Kunden foretager – uafhængigt af Leverandøren – en vurdering af konsekvensen ved et brud på IT- og informationssikkerheden samt ved brud på persondatasikkerheden.

Besvarelsen af spørgeskemaet indgår ikke i evalueringen af tilbudsgivernes tilbud. Besvarelsen af spørgeskemaet anvendes således alene som input til Kundens risikovurdering af risici for brud på IT- og informationssikkerheden samt risikovurdering af risici for brud på persondatasikkerheden efter databeskyttelsesforordningens artikel 32.

Kunden foretager risikovurderingen, og på baggrund af risikovurderingsscore fastsætter Kunden niveauet af sikkerhedskrav, der er relevant for den identificerede risiko, jf. bilag 9 Sikkerhed.

Ved udfyldelsen af spørgeskemaet skal Leverandøren vurdere, om de oplistede sårbarheder (første kolonne i tabellerne) gør sig gældende for Leverandørens Service. Såfremt en given sårbarhed ikke er relevant for Leverandørens Service, skal Leverandøren angive "N/A" i den pågældende række.

En sårbarhed kræver en trussel for at kunne resultere i en risiko og omvendt. Såfremt det kan konstateres, at der foreligger en sårbarhed, skal Leverandøren derfor angive, hvilken trussel (anden kolonne i tabellerne) der knytter sig til denne sårbarhed.

Er den identificerede sårbarhed f.eks., at en bærbar pc ikke er krypteret, kan den tilhørende trussel være, at den bærbare computer bliver stjålet. Kombinationen af denne sårbarhed og trussel vil være, at der foreligger en risiko for, at uvedkommende får adgang til data, herunder personoplysninger, der kan tilgås fra den bærbare computer.

Ved mitigerende foranstaltninger (tredje kolonne i tabellerne) forstås tiltag, som påvirker sandsynligheden ved at reducere eller helt fjerne en sårbarhed eller en trussel. Leverandøren bedes derfor angive mitigerende tekniske og/eller organisatoriske foranstaltninger knyttet til de identificerede sårbarheder og trusler.

De punkter, som Leverandøren skal udfylde, er angivet i skarpe parenteser og markeret med kursiv og rød skrift.

Spørgsmålene er ikke udtømmende og Leverandøren kan angive yderligere sårbarheder, trusler og mitigerende foranstaltninger, der er relevante for Leverandørens Service.]

2 Netværk og tekniske behandlingsmidler

Nr.	Sårbarhed	Trussel	Mitigerende foranstaltning
2.1	Leverandøren bedes oplyse, om dele af behandlingen af Kundens data, herunder personoplysninger, sker gennem internettet, og det er muligt at tilgå Servicen gennem det åbne internet.	Behandling af Kundens data sker gennem internettet, og Servicen kan tilgås gennem det åbne internet. Eksterne trusler kan være hackerangreb (fx DDoS, SQL Injection), Man-in-the-Middle angreb under transmission, Phishing/Credential Stuffing forsøg mod brugere, eller interne trusler som utilsigtet eller intentionel misbrug fra autoriserede brugere.	Mitigerende foranstaltning er bl.a. være opsætning af multifaktorautentifikation (MFA). Kryptering af data in transit (fx TLS/SSL) og at rest (disk-kryptering). Sikkerhedsovervågning (SIEM) for at detektere uregelmæssig adfærd. Regelmæssige penetrationstests. Løbende arbejde med Best Practice indenfor sikkerhed og GDPR.
2.2	Leverandøren bedes oplyse, om det er muligt at tildele administrativ adgang til Servicen, hvori Kundens data, herunder personoplysninger, behandles, gennem internettet.	*Administrativ adgang til Servicen kan tildeles gennem internettet.* *Trusler er hackerangreb (målrettet mod administrationsgrænsefladen) eller interne trusler som utilsigtet eller intentionel misbrug af administrative privilegier.*	Mitigerende foranstaltning er bl.a. *IP-whitelisting for kun at tillade adgang fra bestemte, godkendte IP-adresser (IPSec kan bruges). Stærke adgangskontrolretningslinjer (fx Principle of Least Privilege). Dedikerede administrator-konti og regelmæssig audit af administrative handlinger.*
2.3	Leverandøren bedes oplyse, om Servicen er indbyrdes forbundet med et andet internt eller eksternt it-system/service.	*Servicen er indbyrdes forbundet med et andet internt it-system/service via integration til* Calypso. *Trusler kan være ekstern eller intern trussel om lateral bevægelse (hacker får adgang via et svagere, forbundet*	Mitigerende foranstaltning er bl.a. anvendelse af firewall til at separere ekstern og intern trafik og netværkssegmentering. Implementering af reverse proxy og firewall foran backend-servere. Streng adgangs- og rettighedsstyring for integrationsrammeværket til fx Calypso.

		system) eller utilsigtet for bred brugeradgang til fortrolige oplysninger i de forbundne systemer.	
2.4	Leverandøren bedes oplyse, hvilke sårbarheder der er forbundet med adgangen til de fysiske lokationer, hvorpå Kundens data, inkl. personoplysninger, behandles, herunder om der sker co-lokation med tredjepart, eller der er utilstrækkelig adgangskontrol.	*Sårbarheder forbundet med adgangen til de fysiske lokationer, herunder co-lokation eller utilstrækkelig adgangskontrol kan være en trussel. Dette kan være fysisk indtrængen af uvedkommende (intentionelt eller utilsigtet) for at få adgang til hardware (servere/lagermedier) eller destruktion af hardware.*	Mitigerende foranstaltning er bl.a. effektiv adgangskontrol (fx nøglekort, biometri, adgangskoder) på fysiske lokationer. Videoovervågning af alle indgange og udgange. Overholdelse af anerkendte ISO-standarder. Audit af fysisk adgangslog. Co-lokationsaftaler med sikkerhedskrav til tredjepartleverandør med audit- og revisionsrapporter.
2.5	[*Såfremt der vurderes at være yderligere sårbarheder, bedes Leverandøren angive disse hér.]*	*N/A*	*N/A*

3 Processer og procedurer relateret til behandlingen

Nr.	Sårbarhed	Trussel	Mitigerende foranstaltninger
3.1	Leverandøren bedes oplyse, om fordelingen af roller og ansvar i forbindelse med forretningsprocessen eller databehandlingen er vage eller uklart defineret i relation til leveringen af Leverandørens Service.	*Intern trussel som følge af at fortrolige oplysninger deles med uvedkommende eller at manglende ansvarlighed fører til fejl/forsømmelser.*	*Leverandøren har klare interne politikker for informationssikkerhed og databehandling. Grundig intern oplæring (awareness-programmer). Regelmæssig monitorering og månedlige kontroller med adgange/roller. Beviser for sådanne kontroller auditeres jævnligt.* *Leverandøren er 4 dobbelt ISO certificeret,* **ISO 9001** – Quality Management **ISO 14001** – Environmental Management **ISO 27001** – Information Security **ISO 27701** certification for **Privacy Management**.
3.2	Leverandøren bedes oplyse, om brugertilladelser eller system- og fysiske ressourcer inden for den organisation, der foretager behandlingen, er tvetydige eller uklart defineret.	*Intern trussel som følge af at der utilsigtet gives en for bred brugeradgang (over-privilegering) til fortrolige oplysninger.*	Mitigerende foranstaltning er bl.a. r*egelmæssig vurdering (fx kvartalsvis) af tildelte brugerrettigheder (jf. Principle of Least Privilege). Adgangskontrol baseret på roller (Role-Based Access Control - RBAC). Audit-spor for rettighedsændringer.*
3.3	Leverandøren bedes oplyse, om det er tilladt, at medarbejdere medbringer og anvender eget udstyr forbundet med Servicen (fx tilkobling af egen computer på	*Dette er ikke tilladt*	*Leverandøren er 4 dobbelt ISO certificeret, ISO 9001, ISO 14001,ISO 27001, ISO 27701 og har et træningsprogram alle medarbejdere skal*

	organisationens netværk og anvendelse af private USB-nøgler i organisationens udstyr).		*bestå årligt. Dette indbefatter bl.a også Code of Conduct*
3.4	Leverandøren bedes oplyse, om det er tilladt, at medarbejdere overfører, lagrer eller på anden vis behandler Kundens data, herunder personoplysninger, uden for arbejdspladsen gennem fjernadgang, herunder via privatudstyr.	*Dette er ikke tilladt*	*Leverandøren er 4 dobbelt ISO certificeret, ISO 9001, ISO 14001,ISO 27001, ISO 27701 og har et træningsprogram alle medarbejdere skal bestå årligt. Dette indbefatter bl.a også Code of Conduct*
3.5	Leverandøren bedes oplyse, om der kan foretages behandling af Kundens data, herunder personoplysninger, uden dannelse af log-filer.	*Dette er ikke muligt*	*Leverandøren er 4 dobbelt ISO certificeret, ISO 9001, ISO 14001,ISO 27001, ISO 27701 og har et træningsprogram alle medarbejdere skal bestå årligt. Dette indbefatter bl.a også Code of Conduct*
3.6	*[Såfremt der vurderes at være yderligere sårbarheder, bedes Leverandøren angive disse hér.]*	N/A	N/A

4 Personer og parter involveret i behandlingen

Nr.	Sårbarhed	Trussel	Mitigerende foranstaltninger
4.1	Leverandøren bedes oplyse, om forretningsprocessen udføres, eller om der foretages behandling af data, herunder personoplysninger, af et	Stor udskiftning af medarbejder kan give en trussel der skal håndteres. Ifølge af ansættelse af en person med kriminel baggrund, der kan føre til intentionel	*Leverandøren oplever ikke større udskiftning af medarbejder.* Det er et kendt antal medarbejdere der arbejder og behandler data. *Årlige obligatoriske prøver/genopfriskningskurser for alle medarbejdere. Baggrundscheck*

	ikke nærmere fastsat antal medarbejdere.	datatyveri eller misbrug af privilegier.	*foretages ved ansættelse af nye medarbejdere. Evt. sikkerhedsgodkendelse ved Kundefølsomme data.* *Dette er endvidere en del af de fastlagte processer for opfyldelse af ISO 27701*
4.2	Leverandøren bedes oplyse, om de involverede parter/personers forpligtigelser vedrørende forretningsprocessen, eller vedrørende behandlingen af personoplysninger er tvetydige eller uklart angivet.	*Intern trussel som følge af misforståelse af forpligtelser, der kan føre til datadelinger eller ukorrekt håndtering*	Uddannelse for alle nye medarbejdere. Årlige obligatoriske prøver/genopfriskningskurser. Tydelig dokumentation af roller og ansvar.
4.3	Leverandøren bedes oplyse, om de personer, der behandler Kundens data, herunder personoplysninger, er uerfarne med at arbejde med informationssikkerhed.	*Intern trussel som følge af menneskelige fejl, der fører til utilsigtede datalæk eller forkert konfiguration.*	*Alle medarbejder er grundig oplært ved ansættelse. Årlige genopfriskningskurser og obligatoriske prøver for alle medarbejdere. Et informationssikkerhedsteam der rådgiver og træner.*
4.4	Leverandøren bedes oplyse, om de personer/parter, der behandler Kundens data, herunder personoplysninger, undlader at lagre eller slette oplysninger forsvarligt, herunder i henhold til gældende lovgivning og politikker.	*Risiko for retention (data opbevares længere end nødvendigt) eller at sletning ikke er uigenkaldelig (GDPR overtrædelse).*	*Indeholdt i de ISO understøttende processer. Fastsatte interne politikker for lagring og sletning af data. Automatiseret sletning/arkivering/anonymisering hvor muligt. Sikkerhedsprotokoller for uigenkaldelig sletning.* Alt sletning af data, som sker med hensyn til gældende lovgivning.
4.5	Leverandøren bedes oplyse, om dele af behandlingen foretages af en underleverandør.	*Trussel om at underleverandører ikke opretholder samme ekspertise eller sikkerhedsniveau som Leverandøren.*	*Krav om ISO-certificering af underleverandøren. Tilsyn med underleverandøren (fx årlig audit eller tredjepartsredegørelser). Klar*

			databehandleraftale (DPA) med detaljerede sikkerhedskrav.
4.6	*[Såfremt der vurderes at være yderligere sårbarheder, bedes Leverandøren angive disse hér.]*	*N/A*	*N/A*

5 Sektorspecifikke trusler og behandlingens omfang

Nr.	Sårbarhed	Trussel	Mitigerende foranstaltninger
5.1	Leverandøren bedes oplyse, om den pågældende sektor, som Servicen vedrører, er særligt udsat for cyberangreb.	Det er Leverandørens opfattelse at samtlige sektorer er udsat for cyberangreb. Det er ikke Leverandørens opfattelse af nærværende sektor er mere udsat end andre sektorer.	Leverandøren har et generelt stærkt cyberforsvar og at best practices følges. Leverandøren har et generelt stærkt cyberforsvar. Trusselsovervågning (Threat Intelligence) specifikt rettet mod sektorspecifikke angreb. Regelmæssig sårbarhedshåndtering.
5.2	Leverandøren bedes oplyse, om den organisation, der behandler Kundens data, herunder personoplysninger, har været udsat for cyberangreb eller andre typer af sikkerhedsbrud inden for de sidste 2 år.	Public 360 er ikke blevet udsat for sikkerhedsbrud i forbindelse med cyberangreb de seneste 2 år	*Leverandøren Iværksætter hele tiden ændringer og styrkelse af cyberforsvaret. Bl.a. implementeringen af mitigerende foranstaltninger og regelmæssige sårbarhedsscanninger.* .
5.3	Leverandøren bedes oplyse, om der er modtaget meddelelser og/eller klager med hensyn til Servicens sikkerhed inden for det sidste år.	Leverandøren har ikke modtaget klager over systemet sikkerhed, der givet videre til datatilsynet det seneste år.	*Leverandøren er i tæt dialog med kunder om sikkerhedsspørgsmål.* Leverandøren modtager jævnligt spørgsmål omkring sikkerhed, som Leverandøren løbende i tæt dialog med vores kunder besvarer. Løbende foretages

			penetrationstest for at sikre løsningen bedst muligt.
5.4	Leverandøren bedes oplyse, om behandlingen vedrører en større mængde data, herunder et stort antal personoplysninger om registrerede individer og/eller en stor mængde personoplysninger. Kundens risiko kan stige som følge af en øget trussel rettet mod systemer med større datamængder, eller som følge af øgede konsekvenser ved en kompromittering af større datamængder.	*Leverandøren behandler alle størrelser data med store sikkerhedsforanstaltninger. Kun nødvendige data/oplysninger indsamles (Dataminimering/Privacy by Design). Kryptering af de indsamlede data/oplysninger samt stærk adgangskontrol og overvågning.*	*Stor opmærksomhed omkring awareness og efterlevelse af politikker for persondatasikkerhed (jf. årlige kurser/prøver). Implementering af relevante, specifikke standarder. Der indsamles udelukkende nødvendige data, som Kunden bestemmer omfanget af og data krypteres.*
5.5	Leverandøren bedes oplyse, om der er 'best practice' specifikt rettet mod den organisation, der udfører forretningsprocessen, behandlingen af Kundens data, herunder personoplysninger, der ikke er tilstrækkeligt fulgt.	*Leverandøren arbejder altid ud fra Best Practice på området med sikkerhed og GDPR herunder* udførsel af forretningsprocesser, behandlingen af Kundens data, herunder personoplysninger.	*Stor opmærksomhed omkring awareness og efterlevelse af politikker for persondatasikkerhed (jf. årlige kurser/prøver). Implementering af relevante, specifikke standarder..* Alle medarbejdere med sådanne adgang, grundigt oplært og gennemgår obligatorisk prøver/kurser minimum årligt. Senest er der opnået ISO 27701 certificering, som bevis for stærke processer til overholdelse af dette
5.6	*[Såfremt der vurderes at være yderligere sårbarheder, bedes Leverandøren angive disse hér.]*	*N/A*	*N/A*